



UNIVERSIDAD DE LAS FUERZAS ARMADAS - ESPE
DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

Seguridad de Software

Nombre: Mateo Sosa

NRC: 30808

Fecha: July 28, 2026

Contents

23 - Junio - 2026	5
Objetivos de Aprendizaje	5
Meditación	5
Día del Padre	5
Identificación y Autenticación de Usuarios	5
Autorización y Control de Usuarios	5
25 - Junio - 2026	6
Objetivos de Aprendizaje	6
Meditación	6
El Rey Salomón	6
Protocolos Criptográficos y Sistemas de Autenticación	6
Autenticación Multifactor (MFA)	6
Certificados Digitales	6
Infraestructura de Clave Pública (PKI)	7
Single Sign-On (SSO)	7
30 - Junio - 2026	8
Objetivos de Aprendizaje	8
Meditación	8
Seguridad en Redes	8
Evolución de Protocolos Criptográficos	9
SSL	9
TLS	10
TLS 1.3	10
Kerberos	10
02 - Julio - 2026	12
Objetivos de Aprendizaje	12
Meditación	12
Bill Gates	12
Seguridad en Redes	12
Zero Trust	13
Seguridad Perimetral	13
Tendencias Mundiales de Ciberseguridad	14
07 - Julio - 2026	15
Objetivos de Aprendizaje	15
Meditación	15
Mecanismos de seguridad	16
SNORT	16
Cuadrante Mágico de Gartner UTM (Unified Threat Management) 2026	16
Seguridad en Redes	16
Seguridad Profunda	16
IDS/IPS	16
SIEM	18
UTM	18

Endpoints	19
09 - Julio - 2026	20
Objetivos de Aprendizaje	20
Meditación	20
El amor exige tu mejor versión	20
OWASP	20
Top Ten Attacks	21
WAF	21
Framework de NIST para Desarrollo de Software Seguro	21
Ciclo de Vida del Desarrollo de Software Seguro	22
Pipelines CI/CD	22
14 - Julio - 2026	24
Objetivos de Aprendizaje	24
Meditación	24
Sistema de la Gestión de la Seguridad de la Información	24
ISO/IEC 27000	24
NIST Cybersecurity Framework	24
16 - Julio - 2026	25
Objetivos de Aprendizaje	25
Meditación	25
El Hijo Pródigo	25
Módulos Metasploit	25
Exploit	25
Auxiliary	25
Post	26
Encoders	26
Evasion	26
NOPS	26
OWASP ZAP	26
21 - Julio - 2026	27
Objetivos de Aprendizaje	27
Meditación	27
Exposiciones	27
23 - Julio - 2026	28
Objetivos de Aprendizaje	28
Meditación	28
Estudia	28
Fundamentos de Seguridad de la Información	28
Monitores de Integridad de Archivos (FIM)	28
Seguridad en la Nube y DevSecOps	28
Análisis de Dependencias en Python	29
Blockchain en Votación Electrónica	29

List of Figures

1	Comparativa HTTP vs. HTTPS usando SSL	9
2	Comparativa de flujo de TLS 1.2 vs. TLS 1.3	11
3	Representación de Importancia de Conectividad entre Dispositivos por Red	13
4	Fases de <i>Zero Trust</i>	14
5	Representación Gráfica de Seguridad Perimetral a través de Proxy	15
6	Cuadrante Mágico de Gartner para Unified Threaat Management - Firewalls	17
7	Red LAN siendo protegida por Firewall de la Red WAN	18
8	Open Worldwide Application Security Project	21
9	Software Development Life Cycle	23
10	Estructura de Módulos en Metasploit	25

List of Tables

23 - Junio - 2026

Objetivos de Aprendizaje

1. Identificación y Autenticación de Usuarios
2. Autorización y Control de Usuarios
3. Práctica de Laboratorio: Identificación, Autenticación, Autorización y Control de Usuarios

Meditación

Día del Padre

Para el día del padre, salimos a comer un almuerzo que más le gusta. Luego de eso, nos desplazamos con mis tíos aun parque al cual hemos ido hace 10 años. Fue un momento lindo porque tomamos una foto y comparamos.

Identificación y Autenticación de Usuarios

La identificación y autenticación de usuarios constituyen los primeros mecanismos de seguridad para controlar el acceso a sistemas y aplicaciones. La identificación consiste en que un usuario declare su identidad mediante un identificador único, como un nombre de usuario o correo electrónico, mientras que la autenticación verifica que dicha identidad sea legítima utilizando uno o varios factores de autenticación, como contraseñas, certificados digitales, datos biométricos o códigos temporales.

Actualmente, las organizaciones implementan mecanismos de autenticación cada vez más robustos, como la autenticación multifactor (MFA), para reducir el riesgo de accesos no autorizados. Estas medidas fortalecen la protección de la información al dificultar ataques como el robo de credenciales, la suplantación de identidad y los intentos de fuerza bruta, contribuyendo a garantizar la seguridad de los recursos digitales.

Autorización y Control de Usuarios

La autorización es el proceso mediante el cual un sistema determina qué acciones puede realizar un usuario una vez que su identidad ha sido autenticada. Este proceso se basa en políticas de seguridad, roles, permisos y niveles de privilegio previamente definidos, garantizando que cada usuario únicamente pueda acceder a los recursos necesarios para cumplir sus funciones dentro de la organización.

El control de usuarios complementa la autorización mediante la administración de cuentas, la asignación y revocación de permisos, el monitoreo de actividades y la aplicación del principio de mínimo privilegio. Estas prácticas reducen el riesgo de accesos indebidos, limitan el impacto de posibles incidentes de seguridad y facilitan el cumplimiento de políticas organizacionales y normativas relacionadas con la protección de la información.

25 - Junio - 2026

Objetivos de Aprendizaje

1. Análisis de la Evaluación del Segundo Parcial
2. Protocolos Criptográficos y Sistemas de Autenticación
3. Taller: Métodos de Control de Acceso
4. Práctica de Laboratorio: SSL / TLS

Meditación

El Rey Salomón

1. El que anda con sabios, sabio será. El que anda con necios, será quebrantado.
2. No te asocies con el hombre iracundo y te alies con el hombre violento.
3. Sabiduría ante todo.
4. Así como es el hombre en el fondo de su corazón, así es él.
5. No corrijas al necio porque te verá como enemigo; corrige al sabio y te adorará.
6. Guarda las enseñanzas de tu padre y los consejos de tu madre.
7. La victoria depende de que tengas muchos consejeros.
8. El que es precavido guarda comida durante el verano; el que duerme en la cosecha termina en la vergüenza.
9. Mira a la hormiga y sé sabio.
10. Actuar y no ser perezoso.

Protocolos Criptográficos y Sistemas de Autenticación

Los protocolos criptográficos y los sistemas de autenticación constituyen la base de la seguridad en las comunicaciones y el control de acceso a los sistemas informáticos. Los protocolos criptográficos permiten proteger la información mediante técnicas de cifrado, intercambio seguro de claves y verificación de integridad, mientras que los sistemas de autenticación validan la identidad de los usuarios antes de conceder acceso a los recursos. La combinación de ambos mecanismos garantiza que únicamente usuarios legítimos puedan acceder a la información y que los datos transmitidos permanezcan protegidos frente a interceptaciones, alteraciones o suplantaciones de identidad.

Autenticación Multifactor (MFA)

La autenticación multifactor consiste en verificar la identidad de un usuario mediante dos o más factores de autenticación pertenecientes a diferentes categorías, como algo que conoce (contraseña), algo que posee (token o dispositivo móvil) y algo que es (datos biométricos). Este mecanismo incrementa significativamente la seguridad al reducir el riesgo de accesos no autorizados ocasionados por el robo o filtración de credenciales.

Certificados Digitales

Los certificados digitales son credenciales electrónicas emitidas por una Autoridad Certificadora (CA) que vinculan la identidad de una persona, organización o servidor con una clave pública. Su utilización permite establecer comunicaciones cifradas, autenticar

servidores y usuarios, así como garantizar la autenticidad e integridad de la información intercambiada en servicios como HTTPS y firmas digitales.

Infraestructura de Clave Pública (PKI)

La Infraestructura de Clave Pública (Public Key Infrastructure, PKI) es el conjunto de políticas, componentes y procedimientos encargados de administrar certificados digitales y pares de claves criptográficas. La PKI proporciona los mecanismos necesarios para emitir, validar, renovar y revocar certificados, permitiendo implementar sistemas de autenticación confiables y comunicaciones seguras en redes y aplicaciones.

Single Sign-On (SSO)

Single Sign-On (SSO) es un mecanismo de autenticación que permite a un usuario acceder a múltiples aplicaciones o servicios utilizando una única autenticación. Esta tecnología mejora la experiencia del usuario al reducir la cantidad de credenciales que debe administrar y facilita la gestión centralizada de identidades, manteniendo al mismo tiempo altos niveles de seguridad mediante protocolos de autenticación estandarizados.

30 - Junio - 2026

Objetivos de Aprendizaje

1. Evolución de Protocolos Criptográficos
 - SSL
 - TLS
 - TLS 3.0
 - Kerberos
2. Práctica de Laboratorio: Aplicación de Protocolos Criptográficos TLS/SSL
3. Unidad 3

Meditación

El doctor obtuvo la beca de estudios en 2005. En ese tiempo, pudo ir él pero no su familia ni hijos, pues la visa no les fue otorgada.

Su esposa le pidió que le haga 3 promesas ya que no podían estar juntos:

1. Si se reúne con alguna mujer que le pregunte dónde vive, él no lo diría.
2. En esas conversaciones, no ir diciendo su grado de estudios.
3. No decir que va becado y que dispone de dinero en su bolsillo.

Pasó cerca de un mes y el doctor enfermó por la ausencia de su familia. Un amigo le invitó a un bar de peruanas, donde hubieron 3 escenarios:

1. Un restaurante donde comieron y se saciaron.
2. Un bar donde pudo cantar con emoción
3. La farra, donde el 90% de las personas eran mujeres. El doctor mejor decidió sentarse, sin embargo se encontró con una chica a la que le invitó una cerveza.

Ella le llevó al restaurante y le hizo unas preguntas, entre ellas:

- *¿Dónde vives?*, a la cual respondió *Con 16 personas*
- *¿Qué título tienes?*, a la que respondió *Albañil*
- *¿Cuánto ganas?*, a la que respondió *No tengo dinero*

Seguridad en Redes

Gestionar datos durante la transferencia y su almacenamiento.

- Internet
- Dispositivos móviles
- Redes de datos
- Aplicaciones Web
- Redes celulares
- Infraestructuras de misión crítica

Evolución de Protocolos Criptográficos

La evolución de los protocolos criptográficos ha sido fundamental para fortalecer la seguridad de las comunicaciones en redes y aplicaciones. A medida que surgieron nuevas amenazas y aumentó la capacidad computacional, los mecanismos de cifrado debieron actualizarse para corregir vulnerabilidades y ofrecer mejores garantías de confidencialidad, integridad y autenticación. Esta evolución permitió que las comunicaciones digitales fueran cada vez más seguras y confiables.

El desarrollo de nuevos protocolos también ha impulsado la adopción de estándares internacionales y mejores prácticas para la protección de la información. Comprender cómo han evolucionado estos protocolos permite identificar las limitaciones de tecnologías antiguas y valorar la importancia de mantener sistemas actualizados frente a los constantes avances en ciberseguridad.

SSL

Secure Sockets Layer (SSL) fue uno de los primeros protocolos ampliamente utilizados para establecer comunicaciones cifradas entre clientes y servidores a través de Internet. Su principal objetivo era proteger la información transmitida mediante el uso de criptografía, evitando que terceros pudieran interceptar o modificar los datos durante la comunicación.

Con el paso del tiempo, se descubrieron diversas vulnerabilidades en SSL que comprometían su seguridad, como ataques relacionados con versiones antiguas del protocolo. Debido a estas debilidades, SSL fue reemplazado progresivamente por TLS, aunque su nombre aún es utilizado de forma coloquial para referirse a conexiones seguras, especialmente en el contexto de certificados digitales.

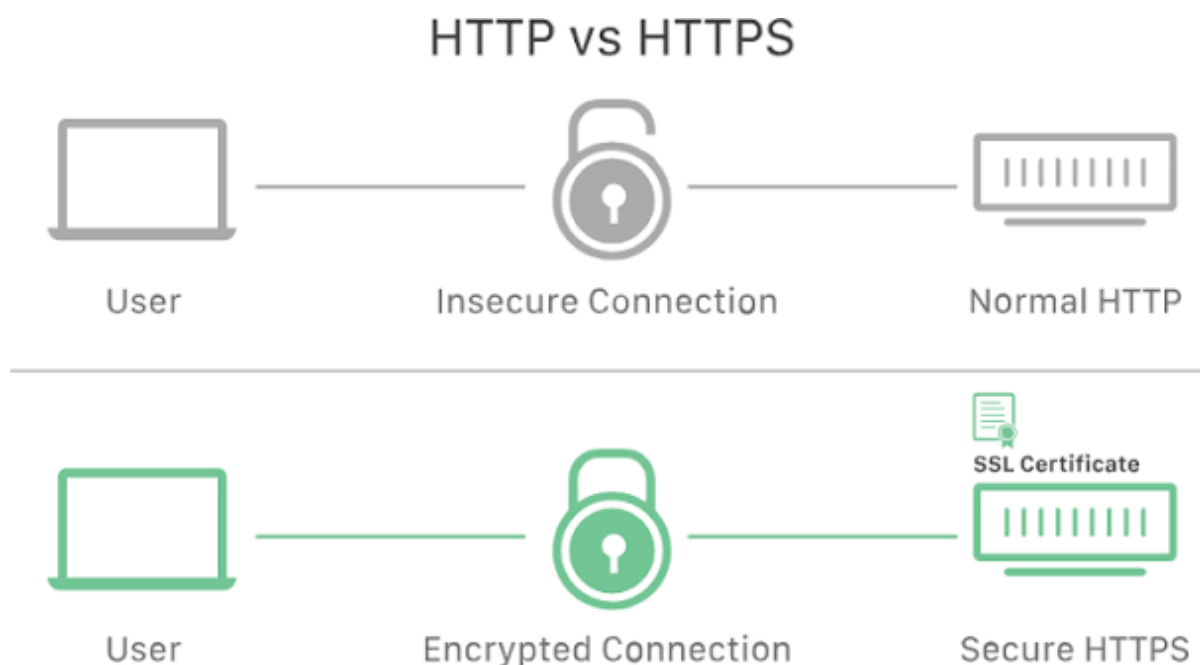


Figure 1: Comparativa HTTP vs. HTTPS usando SSL

TLS

Transport Layer Security (TLS) es el protocolo que sustituyó a SSL, incorporando mejoras significativas en los algoritmos criptográficos, el proceso de negociación de claves y la autenticación entre las partes. Su función es garantizar que la información intercambiada entre un cliente y un servidor permanezca protegida contra espionaje, manipulación e intentos de suplantación de identidad.

TLS es actualmente el estándar utilizado para proteger servicios como HTTPS, correo electrónico, VPN y numerosas aplicaciones de Internet. Gracias a su diseño modular y a la incorporación de algoritmos criptográficos modernos, ofrece un alto nivel de seguridad y continúa evolucionando para responder a nuevas amenazas y requisitos tecnológicos.

TLS 1.3

TLS 1.3 representa la versión más reciente y segura del protocolo TLS, diseñada para simplificar el establecimiento de conexiones seguras y eliminar algoritmos criptográficos considerados inseguros. Esta versión reduce el número de intercambios necesarios durante el proceso de handshake, mejorando tanto la seguridad como el rendimiento de las comunicaciones.

Entre sus principales ventajas se encuentran el uso obligatorio de algoritmos criptográficos robustos, la eliminación de funciones obsoletas y una mayor protección frente a diversos tipos de ataques. Estas mejoras convierten a TLS 1.3 en el protocolo recomendado para proteger aplicaciones y servicios modernos que requieren comunicaciones rápidas y altamente seguras.

Kerberos

Kerberos es un protocolo de autenticación de red que permite verificar la identidad de usuarios y servicios mediante el uso de tickets criptográficos, evitando el envío repetido de contraseñas a través de la red. Su funcionamiento se basa en un tercero de confianza denominado Key Distribution Center (KDC), encargado de emitir los tickets necesarios para autenticar a los participantes.

Este protocolo es ampliamente utilizado en entornos empresariales y redes corporativas debido a su capacidad para proporcionar autenticación mutua entre clientes y servidores. Además de incrementar la seguridad, Kerberos facilita la implementación de mecanismos de inicio de sesión único (Single Sign-On), permitiendo que los usuarios accedan a múltiples servicios utilizando una única autenticación.

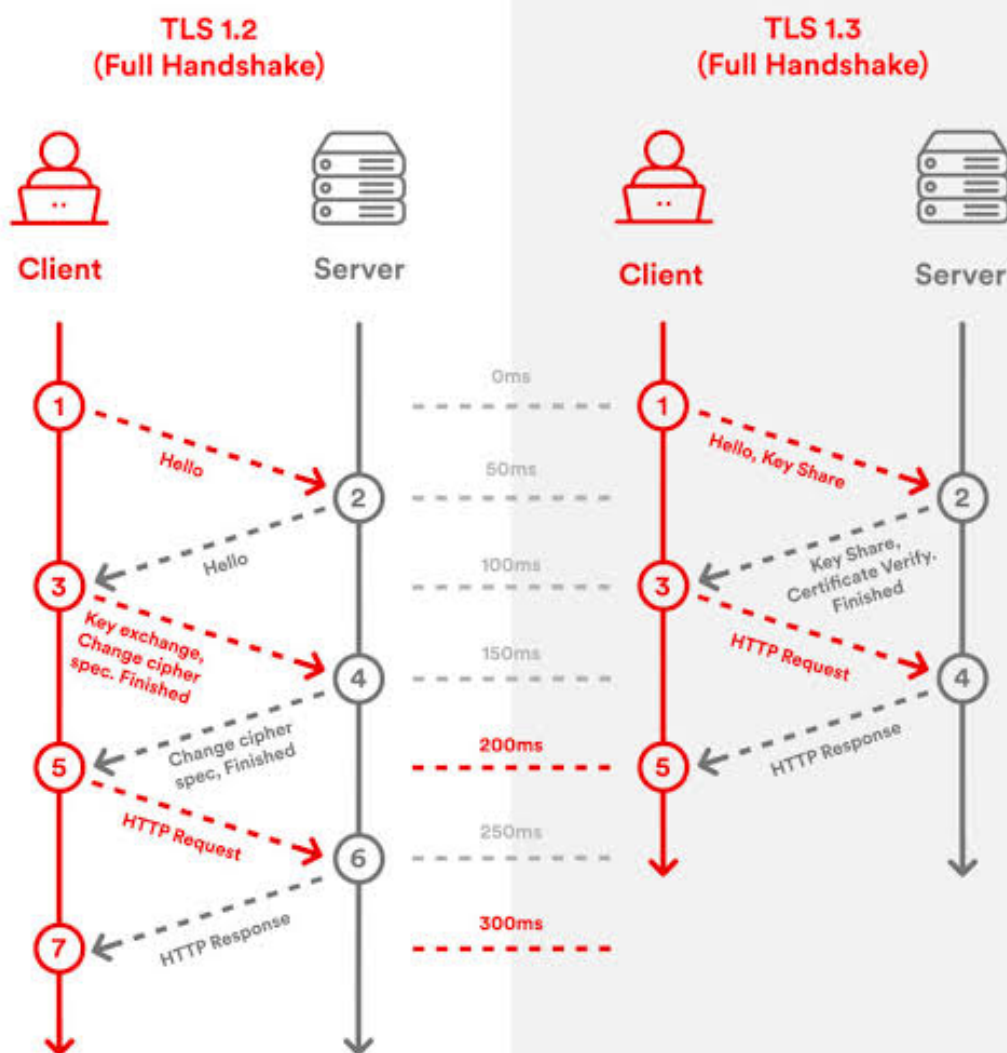


Figure 2: Comparativa de flujo de TLS 1.2 vs. TLS 1.3

02 - Julio - 2026

Objetivos de Aprendizaje

1. Seguridad en Redes
 - Zero Trust
 - Seguridad Perimetral
2. Tendencias Mundiales de Ciberseguridad
3. Práctica de Laboratorio:

Meditación

Bill Gates

Bill Gates nació el 28 de octubre de 1955 en Seattle, Washington, Estados Unidos. Desde temprana edad mostró un gran interés por la informática y la programación, desarrollando sus primeras aplicaciones cuando aún era estudiante. En 1975, junto con su amigo Paul Allen, fundó Microsoft, empresa que revolucionó la industria del software al desarrollar sistemas operativos y herramientas que facilitaron el acceso de millones de personas a la computación personal. Su liderazgo permitió que Microsoft se consolidara como una de las compañías tecnológicas más influyentes del mundo.

Durante su trayectoria empresarial, Bill Gates impulsó el desarrollo de productos emblemáticos como MS-DOS y Windows, los cuales transformaron la forma en que las personas interactúan con las computadoras. Además de su visión tecnológica, destacó por promover la innovación y la estandarización del software, contribuyendo al crecimiento de la industria informática y al avance de numerosas empresas dedicadas al desarrollo tecnológico. Su trabajo influyó significativamente en la expansión de Internet, la productividad empresarial y la educación digital.

En años más recientes, Bill Gates ha dedicado gran parte de sus esfuerzos a la filantropía mediante la Fundación Bill y Melinda Gates, enfocándose en áreas como salud pública, educación, reducción de la pobreza e investigación científica. A través de diversas iniciativas ha apoyado programas de vacunación, desarrollo sostenible y acceso a oportunidades educativas en distintos países. Su legado combina tanto las contribuciones realizadas al mundo de la tecnología como su impacto en proyectos destinados a mejorar la calidad de vida de millones de personas alrededor del mundo.

Seguridad en Redes

La seguridad en redes comprende el conjunto de políticas, tecnologías y procedimientos destinados a proteger la infraestructura de comunicación, los dispositivos conectados y la información que circula entre ellos. Su propósito es prevenir accesos no autorizados, detectar actividades maliciosas y garantizar la disponibilidad de los servicios frente a amenazas internas y externas. Para ello, se emplean mecanismos como firewalls, sistemas de detección y prevención de intrusiones, segmentación de redes y monitoreo continuo.

En la actualidad, la seguridad en redes debe adaptarse a entornos cada vez más distribuidos, donde el trabajo remoto, la computación en la nube y los dispositivos móviles incrementan la superficie de ataque. Por esta razón, las organizaciones implementan estrategias



Figure 3: Representación de Importancia de Conectividad entre Dispositivos por Red

integrales que combinan controles técnicos, políticas de acceso y capacitación del personal para reducir riesgos y fortalecer la resiliencia frente a incidentes de ciberseguridad.

Zero Trust

Zero Trust es un modelo de seguridad basado en el principio de “nunca confiar, siempre verificar”. A diferencia de los modelos tradicionales, este enfoque asume que ningún usuario, dispositivo o aplicación debe considerarse confiable por defecto, incluso si se encuentra dentro de la red corporativa. Cada solicitud de acceso debe autenticarse, autorizarse y validarse continuamente antes de conceder permisos.

La implementación de Zero Trust requiere mecanismos como autenticación multifactor, control de acceso con privilegios mínimos, segmentación de la red y monitoreo permanente de las actividades de los usuarios. Este modelo reduce el impacto de posibles compromisos de seguridad y limita el movimiento lateral de los atacantes dentro de la infraestructura, convirtiéndose en una estrategia ampliamente adoptada por organizaciones modernas.

Seguridad Perimetral

La seguridad perimetral consiste en proteger el límite entre la red interna de una organización y las redes externas, especialmente Internet. Tradicionalmente, esta estrategia se ha basado en la implementación de firewalls, proxies, sistemas de detección y prevención de intrusiones, así como filtros de tráfico que controlan el acceso hacia los recursos internos.

Aunque la seguridad perimetral continúa siendo un componente importante de la defensa informática, por sí sola ya no resulta suficiente frente a las amenazas actuales. La adopción de servicios en la nube, dispositivos móviles y acceso remoto ha impulsado la necesidad de

ZERO TRUST SECURITY



Figure 4: Fases de *Zero Trust*

complementar el perímetro con enfoques como Zero Trust, garantizando una protección más completa y adaptable a los entornos modernos.

Tendencias Mundiales de Ciberseguridad

Las tendencias mundiales de ciberseguridad reflejan la constante evolución de las amenazas y de las tecnologías empleadas para proteger la información. Entre las principales tendencias destacan el incremento de ataques de ransomware, el uso de inteligencia artificial tanto para la defensa como para los ataques, la protección de infraestructuras críticas, la seguridad en entornos de nube y la adopción de arquitecturas Zero Trust.

Asimismo, las organizaciones están fortaleciendo sus estrategias mediante automatización, análisis avanzado de amenazas, respuesta temprana a incidentes y cumplimiento de estándares internacionales. Estas tendencias evidencian que la ciberseguridad se ha convertido en un aspecto estratégico para gobiernos, empresas e instituciones, requiriendo una actualización constante de conocimientos y tecnologías para enfrentar riesgos cada vez más sofisticados.



Figure 5: Representación Gráfica de Seguridad Perimetral a través de Proxy

07 - Julio - 2026

Objetivos de Aprendizaje

1. Seguridad en Redes
 - Seguridad profunda
 - IDS/IPS
 - Firewall
 - NewGenFirewall
 - Web Application Firewall
 - SIEM
 - UTM
 - Endpoints
2. Práctica de Laboratorio: Configuración de Firewalls en Linux

Meditación

3 versículos de la biblia

1. Proverbios 1:8
2. Proverbios 22:6
3. Éxodo 20:12

Mecanismos de seguridad

IDS: Instruction Detection System IPS: Instruction Prevention System

Se definen políticas de acceso, detección y prevención.

SNORT

Cuadrante Mágico de Gartner UTM (Unified Threat Management) 2026

Seguridad en Redes

La seguridad en redes comprende el conjunto de estrategias, tecnologías y procedimientos destinados a proteger la infraestructura de comunicación y los datos que circulan a través de ella. Su finalidad es garantizar la confidencialidad, integridad y disponibilidad de la información, previniendo accesos no autorizados, ataques cibernéticos y fallos que puedan comprometer la operación de los servicios. Para lograrlo, se implementan múltiples capas de protección que actúan de forma complementaria.

Las organizaciones modernas requieren una estrategia de seguridad integral debido al incremento de amenazas, la adopción de servicios en la nube y el trabajo remoto. En este contexto, la seguridad en redes combina herramientas de prevención, detección y respuesta que permiten identificar actividades sospechosas, contener incidentes y reducir el impacto de posibles ataques sobre la infraestructura tecnológica.

Seguridad Profunda

La seguridad profunda, conocida también como Defense in Depth, es una estrategia que consiste en implementar múltiples capas de protección para evitar que una única vulnerabilidad comprometa todo el sistema. En lugar de depender de un solo mecanismo de defensa, este enfoque integra controles físicos, administrativos y tecnológicos que trabajan conjuntamente para dificultar el éxito de un ataque.

Este modelo contempla medidas como autenticación multifactor, segmentación de redes, cifrado de datos, monitoreo continuo, políticas de acceso y capacitación de usuarios. La combinación de estas capas incrementa la resiliencia de la organización, permitiendo detectar amenazas oportunamente y minimizar el impacto de incidentes de seguridad.

IDS/IPS

Los sistemas IDS (Intrusion Detection System) e IPS (Intrusion Prevention System) son herramientas diseñadas para identificar actividades maliciosas dentro de una red informática. Mientras un IDS monitorea el tráfico y genera alertas cuando detecta comportamientos sospechosos, un IPS va un paso más allá al bloquear automáticamente el tráfico considerado peligroso antes de que alcance los sistemas protegidos.

Estos sistemas emplean firmas conocidas, análisis de comportamiento y técnicas de detección de anomalías para identificar ataques como escaneos de puertos, explotación de vulnerabilidades, malware o intentos de acceso no autorizado. Su integración con otras soluciones de seguridad fortalece la capacidad de respuesta ante amenazas y mejora la protección de la infraestructura tecnológica.

Seguridad de Software

Figure 1: Magic Quadrant for CPS Protection Platforms



Figure 6: Cuadrante Mágico de Gartner para Unified Threaat Management - Firewalls

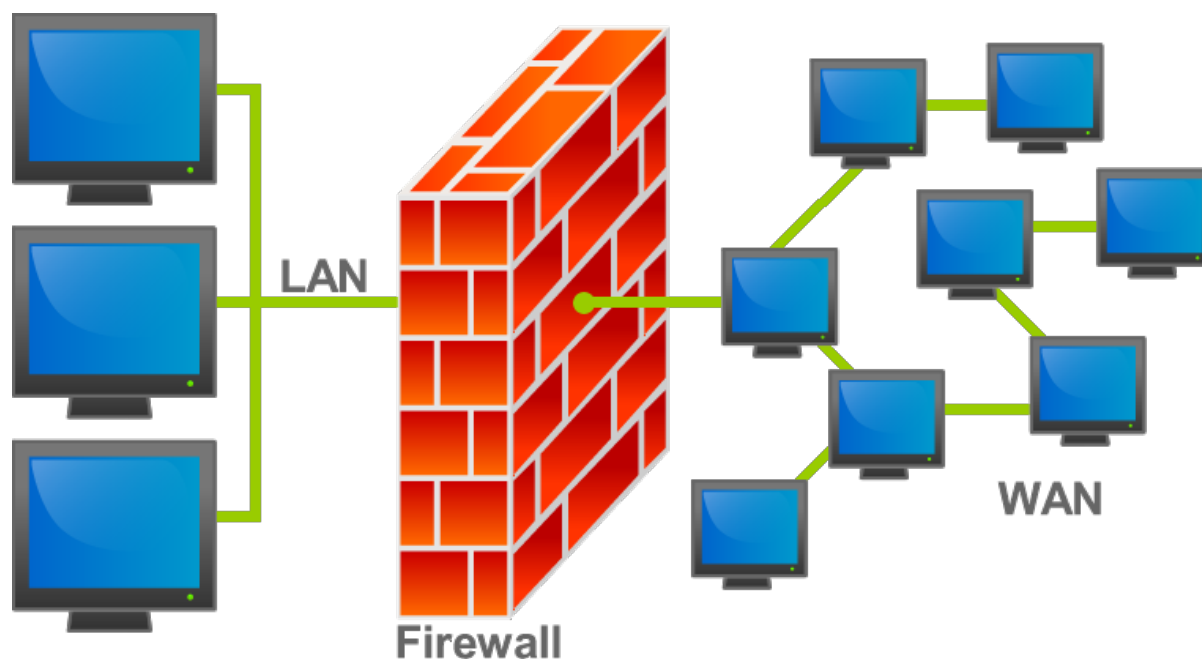


Figure 7: Red LAN siendo protegida por Firewall de la Red WAN

Firewall Dispositivo o software encargado de controlar el tráfico de red mediante reglas previamente definidas que permiten o bloquean conexiones según criterios de seguridad.

Next Generation Firewall (NGFW) Evolución de los firewalls tradicionales al incorporar funciones avanzadas.

Web Application Firewall (WAF) Mecanismo especializado en proteger aplicaciones web frente a ataques dirigidos contra el protocolo HTTP y HTTPS.

SIEM

Security Information and Event Management (SIEM) es una plataforma que centraliza la recopilación, correlación y análisis de registros generados por servidores, aplicaciones, dispositivos de red y herramientas de seguridad. Su objetivo es proporcionar una visión unificada del estado de seguridad de una organización y facilitar la detección temprana de incidentes.

Los sistemas SIEM permiten automatizar alertas, generar reportes de cumplimiento normativo e identificar comportamientos anómalos mediante reglas de correlación y análisis avanzado de eventos. Estas capacidades mejoran la capacidad de respuesta de los equipos de seguridad y reducen el tiempo necesario para investigar y contener posibles ataques.

UTM

Unified Threat Management (UTM) es una solución de seguridad que integra múltiples funciones de protección dentro de un único dispositivo o plataforma. Generalmente combina firewall, antivirus, filtrado web, VPN, sistemas IDS/IPS, control de aplicaciones y otras herramientas destinadas a simplificar la administración de la seguridad informática.

La principal ventaja de un UTM es centralizar la gestión de diferentes mecanismos de protección, reduciendo la complejidad operativa y facilitando el monitoreo de la infraestructura. Esta integración resulta especialmente útil para pequeñas y medianas organizaciones que requieren una solución completa sin administrar múltiples dispositivos independientes.

Endpoints

Los endpoints son todos aquellos dispositivos finales que se conectan a una red, como computadoras, servidores, teléfonos móviles, tabletas e incluso dispositivos del Internet de las Cosas (IoT). Debido a que representan uno de los principales puntos de acceso para los atacantes, protegerlos constituye un aspecto esencial dentro de cualquier estrategia de ciberseguridad.

La seguridad de endpoints incluye el uso de antivirus, soluciones EDR (Endpoint Detection and Response), cifrado de discos, control de aplicaciones, administración de parches y monitoreo continuo. Estas medidas permiten prevenir infecciones por malware, detectar actividades sospechosas y responder rápidamente ante incidentes que puedan comprometer los dispositivos y la información que almacenan.

09 - Julio - 2026

Objetivos de Aprendizaje

1. Seguridad en Aplicaciones
 - Web
 - OSAWP
 - Top Ten Attacks
 - WAF
 - Framework de NIST Desarrollo de Software Seguro
 - Ciclo de Vida del Desarrollo de Software Seguro
 - Pipelines CI/CD
2. Práctica de Laboratorio: SNORT + SQL Injection

Meditación

El amor exige tu mejor versión

El doctor fue a Caracas, Venezuela.

Hace tiempo, habló con el rector de la universidad para hacer un proyecto relacionado con Cisco. El rector le cedió el permiso y los recursos necesarios para capacitarse. Para poder capacitarse, los cursos fueron en Venezuela, por lo que fue con unos compañeros suyos.

Para poder conseguir un certificado, el doctor tuvo que realizar un curso de 33 niveles. Por ello, el doctor tuvo que realizar un examen diario.

En el examen final, el doctor sacó una calificación insatisfactoria, por lo que se sintió muy mal. Se retiró de la clase y llamó a su mujer. Su mujer, por su parte, le colgó 3 veces diciéndole que no podía rendirse. Que él era un ejemplo a seguir, no debería hacer un berrinche por ello.

Al terminar la 3ra llamada, se fue al curso nuevamente y volvió a esforzarse.

Nosotros no somos perdedores ni somos “pobrecitos”, sin dejar de ser humildes.

OWASP

OWASP Open Worldwide Application Security Project

OWASP (Open Worldwide Application Security Project) es una organización internacional sin fines de lucro dedicada a mejorar la seguridad del software mediante la creación de recursos abiertos para desarrolladores, empresas y profesionales de ciberseguridad. La organización publica documentación, herramientas, metodologías y proyectos que ayudan a identificar y mitigar vulnerabilidades presentes en aplicaciones web y otros sistemas informáticos.

Entre sus contribuciones más reconocidas se encuentra el OWASP Top 10, además de proyectos como ASVS, WebGoat, ZAP y Cheat Sheets. Estos recursos sirven como referencia para implementar buenas prácticas de desarrollo seguro, realizar pruebas de seguridad y capacitar a equipos técnicos. Gracias a su enfoque colaborativo y de libre

acceso, OWASP se ha convertido en uno de los estándares más utilizados en la industria para fortalecer la seguridad del software.



Figure 8: Open Worldwide Application Security Project

Top Ten Attacks

El OWASP Top 10 reúne las diez categorías de vulnerabilidades más críticas y frecuentes identificadas en aplicaciones web. Esta clasificación se basa en datos recopilados por expertos en seguridad y organizaciones de todo el mundo, proporcionando una guía para priorizar riesgos y enfocar los esfuerzos de protección durante el desarrollo de software.

Entre las vulnerabilidades más comunes se encuentran el control de acceso roto, fallas criptográficas, inyección, diseño inseguro, configuraciones de seguridad incorrectas y componentes vulnerables o desactualizados. Conocer estas amenazas permite a los desarrolladores implementar controles preventivos, realizar pruebas específicas y disminuir la probabilidad de que una aplicación sea comprometida por atacantes.

WAF

Un Web Application Firewall (WAF) es un mecanismo de seguridad diseñado para proteger aplicaciones web filtrando, monitoreando y bloqueando tráfico HTTP o HTTPS malicioso antes de que alcance el servidor. A diferencia de un firewall tradicional, un WAF analiza las solicitudes considerando el comportamiento de la aplicación, permitiendo identificar ataques específicos dirigidos contra servicios web.

Los WAF pueden detectar intentos de inyección SQL, Cross-Site Scripting (XSS), ataques de fuerza bruta y otras amenazas comunes descritas por OWASP. Su implementación constituye una capa adicional de defensa que complementa las medidas de seguridad incorporadas en el desarrollo, aunque no reemplaza la necesidad de escribir código seguro y mantener una adecuada gestión de vulnerabilidades.

Framework de NIST para Desarrollo de Software Seguro

El NIST Secure Software Development Framework (SSDF) es un marco de referencia que proporciona recomendaciones para integrar prácticas de seguridad durante todo el

proceso de desarrollo de software. Su propósito es reducir la cantidad de vulnerabilidades presentes en los productos, mejorar la protección de la cadena de suministro de software y facilitar la respuesta ante incidentes de seguridad.

El SSDF organiza sus recomendaciones en prácticas relacionadas con la preparación de la organización, la protección del software, la producción de software seguro y la respuesta a vulnerabilidades. Estas directrices pueden adaptarse a diferentes metodologías de desarrollo y ayudan a establecer procesos consistentes que incrementan la calidad y seguridad de las aplicaciones.

Ciclo de Vida del Desarrollo de Software Seguro

El Ciclo de Vida del Desarrollo de Software Seguro (SSDLC) amplía el ciclo tradicional de desarrollo incorporando actividades de seguridad en cada una de sus fases, desde el levantamiento de requisitos hasta el mantenimiento del sistema. Este enfoque busca identificar riesgos de forma temprana, disminuyendo el costo de corregir vulnerabilidades detectadas en etapas avanzadas.

Durante el SSDLC se realizan actividades como análisis de riesgos, modelado de amenazas, revisiones de código, pruebas de seguridad estáticas y dinámicas, validación de configuraciones y monitoreo posterior al despliegue. La integración de estas prácticas permite desarrollar aplicaciones más confiables y resilientes frente a amenazas emergentes.

Pipelines CI/CD

Los pipelines de Integración Continua y Entrega Continua (CI/CD) automatizan las tareas de construcción, pruebas y despliegue de aplicaciones, permitiendo entregar nuevas versiones de manera rápida y consistente. La automatización reduce errores humanos, mejora la calidad del software y facilita la detección temprana de fallos durante el proceso de desarrollo.

Desde la perspectiva de la seguridad, los pipelines CI/CD permiten incorporar prácticas de DevSecOps mediante la ejecución automática de análisis de código estático, escaneo de dependencias, pruebas de vulnerabilidades y validación de configuraciones antes del despliegue. Integrar estos controles en el pipeline ayuda a prevenir la propagación de vulnerabilidades hacia ambientes de producción y fortalece el proceso de desarrollo seguro.

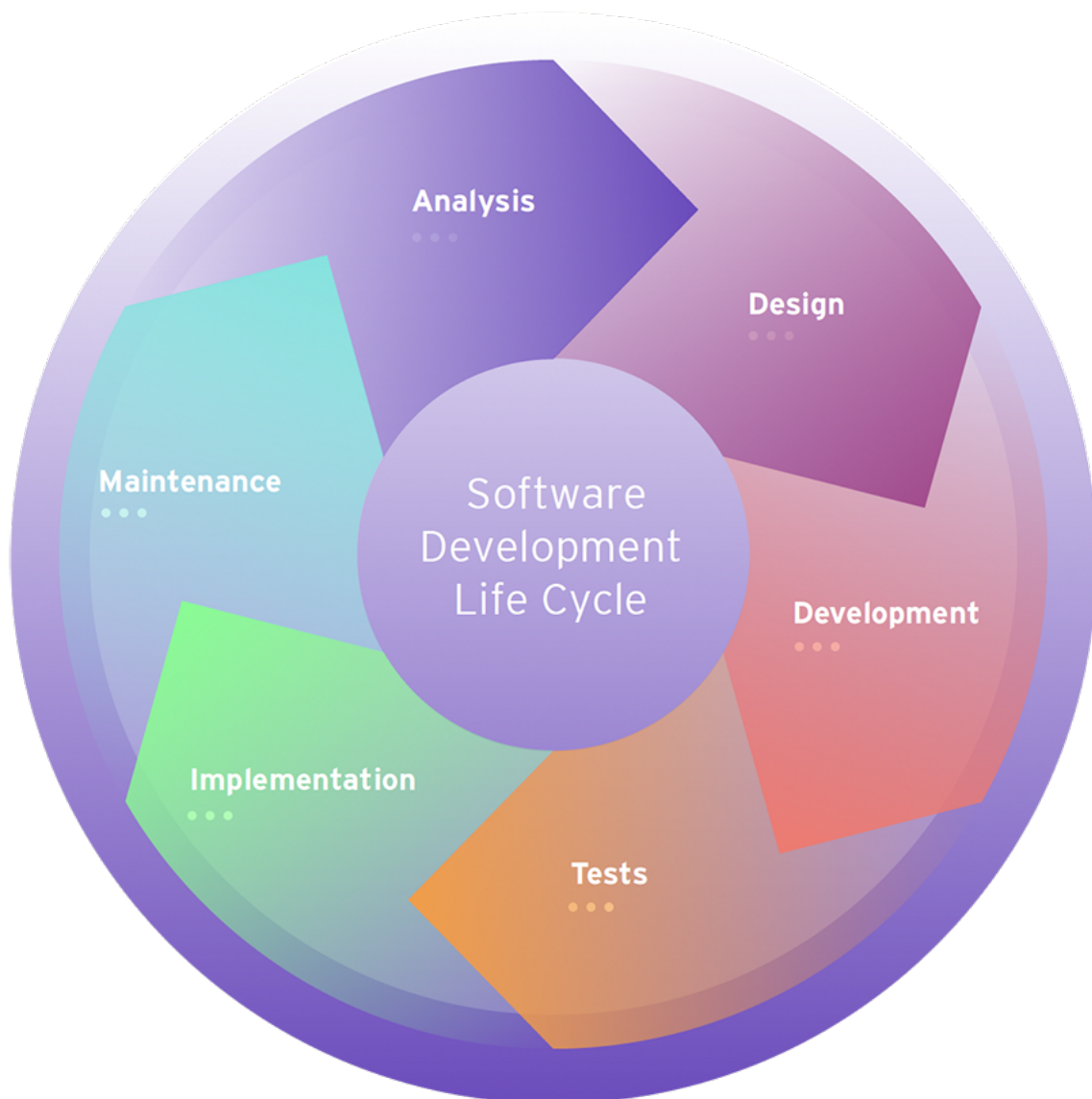


Figure 9: Software Development Life Cycle

14 - Julio - 2026

Objetivos de Aprendizaje

1. Sistema de Gestión de la Seguridad de la Información
 - ISO-27000
 - NIST CyberSecurity Framework
2. Taller: Comparación entre ISO/IEC 27002 & NIST CF

Meditación

Where the hell is matt

Sistema de la Gestión de la Seguridad de la Información

ISO/IEC 27000

La familia de normas ISO/IEC 27000 constituye un conjunto de estándares internacionales orientados a la gestión de la seguridad de la información. Estas normas proporcionan un marco de referencia para establecer, implementar, mantener y mejorar un Sistema de Gestión de la Seguridad de la Información (SGSI), promoviendo un enfoque basado en la gestión de riesgos y la mejora continua.

Dentro de esta familia, la norma ISO/IEC 27001 establece los requisitos para implementar un SGSI, mientras que otras normas complementarias ofrecen directrices sobre controles de seguridad, gestión de riesgos, auditorías y protección de activos de información. La adopción de estos estándares permite a las organizaciones demostrar su compromiso con la seguridad y facilitar el cumplimiento de regulaciones nacionales e internacionales.

NIST Cybersecurity Framework

El NIST Cybersecurity Framework (CSF) es un marco de referencia desarrollado por el Instituto Nacional de Estándares y Tecnología (NIST) de los Estados Unidos para ayudar a las organizaciones a gestionar y reducir los riesgos relacionados con la ciberseguridad. Su estructura flexible permite que sea aplicado por organizaciones de diferentes tamaños y sectores, adaptándose a sus necesidades y niveles de madurez en seguridad.

El marco organiza las actividades de ciberseguridad en funciones fundamentales como Gobernar (Govern), Identificar (Identify), Proteger (Protect), Detectar (Detect), Responder (Respond) y Recuperar (Recover). Estas funciones facilitan la evaluación del estado de seguridad de una organización, la priorización de inversiones y el establecimiento de procesos que fortalecen la resiliencia frente a incidentes y amenazas emergentes.

16 - Julio - 2026

Objetivos de Aprendizaje

1. CIS Controls
2. Metasploit

Meditación

El Hijo Pródigo

Módulos Metasploit

Metasploit modules

There are currently 6654 Metasploit modules:

[Expand All](#) [Collapse All](#)



Figure 10: Estructura de Módulos en Metasploit

Exploit

Los módulos Exploit contienen el código necesario para aprovechar una vulnerabilidad específica presente en un sistema, servicio o aplicación. Su objetivo es ejecutar una acción sobre el objetivo vulnerable, como obtener acceso remoto, ejecutar comandos o instalar una carga útil (payload) que permita continuar con la prueba de penetración.

Auxiliary

Los módulos Auxiliary agrupan herramientas que no requieren explotar una vulnerabilidad para cumplir su función. Incluyen utilidades destinadas al reconocimiento, escaneo de puertos, enumeración de servicios, recopilación de información, ataques de fuerza bruta y

comprobación de vulnerabilidades, entre otras tareas relacionadas con la evaluación de seguridad.

Post

Los módulos Post se utilizan después de haber obtenido acceso a un sistema mediante un exploit exitoso. Su finalidad es realizar actividades de postexplotación como la recopilación de información del sistema, escalamiento de privilegios, extracción de credenciales, análisis de configuraciones y evaluación del impacto que tendría un atacante con acceso al equipo comprometido.

Encoders

Los módulos Encoders permiten transformar o codificar un payload para modificar su representación sin alterar su funcionamiento. Originalmente fueron diseñados para evitar caracteres problemáticos durante la explotación y, en algunos casos, dificultar la detección por parte de ciertos mecanismos de seguridad.

Evasion

Los módulos Evasion están orientados a generar cargas útiles capaces de evadir algunos mecanismos de detección implementados por soluciones de seguridad, como antivirus o sistemas de protección de endpoints, dentro de entornos de prueba autorizados. Estos módulos permiten evaluar la eficacia de los controles defensivos y detectar posibles debilidades en la infraestructura de seguridad.

NOPS

Los módulos NOPS generan secuencias de instrucciones conocidas como No Operation (NOP), cuya función es preparar el entorno para la ejecución de un payload. Estas instrucciones no producen cambios en el sistema, pero ayudan a incrementar la probabilidad de que la ejecución alcance correctamente la carga útil durante determinados procesos de explotación.

OWASP ZAP

OWASP ZAP (Zed Attack Proxy) es una herramienta de código abierto desarrollada por OWASP para realizar pruebas de seguridad en aplicaciones web. Funciona como un proxy de interceptación que permite analizar el tráfico HTTP y HTTPS entre el navegador y la aplicación, facilitando la identificación de vulnerabilidades como inyección SQL, Cross-Site Scripting (XSS), configuraciones inseguras y otros riesgos presentes en aplicaciones web.

Además de su capacidad para realizar análisis automáticos de vulnerabilidades, OWASP ZAP ofrece herramientas para pruebas manuales, inspección de solicitudes y respuestas, manipulación de parámetros y generación de reportes de seguridad. Gracias a su facilidad de uso y a su amplia comunidad de desarrollo, se ha convertido en una de las herramientas más utilizadas para apoyar auditorías de seguridad y procesos de desarrollo seguro.

21 - Julio - 2026

Objetivos de Aprendizaje

1. Temas actuales de seguridad de la información

Meditación

Filipenses 4:4

Salmo 23

Salmo 27

Filipenses 4:13

Mateo 28:20

Exposiciones

- Threat Hunting Automatizado
- Inteligencia de Amenazas (Threat Intelligence)
- Seguridad de Identidad y Detección de Amenazas (ITDR)

23 - Julio - 2026

Objetivos de Aprendizaje

1. Fundamentos de Seguridad de la Información
2. Monitores de Integridad de Archivos (FIM)
3. Seguridad en la Nube y DevSecOps
4. Análisis de Dependencias en Python
5. Blockchain en Votación Electrónica

Meditación

Estudia

La reflexión de la última clase se resumió en una sola palabra: **estudiar**, enfatizando la importancia de la disciplina ante el cierre del parcial. Este mensaje recordó que el aprendizaje adquirido en clase debe reforzarse mediante la revisión y la práctica individual. En preparación para la evaluación acumulativa, estudiar se convierte en la principal herramienta para consolidar los conocimientos obtenidos durante el bimestre.

Fundamentos de Seguridad de la Información

La seguridad de la información, la ciberseguridad, el ciberespacio y la ciberdefensa son conceptos relacionados que permiten comprender cómo se protege la información, las infraestructuras tecnológicas y los servicios digitales frente a amenazas. Aunque cada uno tiene un enfoque particular, todos contribuyen a garantizar la confidencialidad, integridad y disponibilidad de los activos de información.

Comprender la relación entre estos conceptos facilita el diseño de estrategias de protección más completas y adaptadas a los riesgos actuales. Además, proporciona una base conceptual sólida para analizar incidentes, implementar controles de seguridad y participar en la gestión integral de la seguridad informática.

Monitores de Integridad de Archivos (FIM)

Los monitores de integridad de archivos (File Integrity Monitoring, FIM) son herramientas que supervisan cambios realizados sobre archivos y directorios críticos de un sistema. Su objetivo es detectar modificaciones no autorizadas que puedan indicar un ataque, una configuración incorrecta o una alteración maliciosa de la información.

Estas soluciones permiten generar alertas cuando se identifican cambios inesperados, facilitando la detección temprana de incidentes de seguridad. El uso de FIM complementa otras medidas de protección y contribuye a fortalecer los procesos de auditoría, cumplimiento normativo y respuesta ante incidentes.

Seguridad en la Nube y DevSecOps

La seguridad en la nube busca proteger los datos, aplicaciones y servicios alojados en infraestructuras de computación en la nube mediante controles técnicos, políticas y mecanismos de monitoreo. Por su parte, DevSecOps integra prácticas de seguridad dentro

de los procesos de desarrollo y despliegue continuo, incorporando controles desde las primeras etapas del ciclo de vida del software.

La combinación de ambos enfoques permite automatizar pruebas de seguridad, gestionar vulnerabilidades y proteger aplicaciones modernas de forma continua. Esto favorece la entrega de software más seguro sin afectar la velocidad de desarrollo ni la calidad de los servicios.

Análisis de Dependencias en Python

El análisis de dependencias en proyectos Python consiste en evaluar las bibliotecas utilizadas por una aplicación para identificar vulnerabilidades conocidas, versiones obsoletas y posibles riesgos de seguridad. Esta práctica ayuda a reducir la exposición a ataques derivados del uso de componentes de terceros.

Existen diversas herramientas que automatizan este proceso, permitiendo detectar dependencias vulnerables y recomendar actualizaciones o alternativas más seguras. Integrar estos análisis dentro del proceso de desarrollo fortalece la seguridad de la cadena de suministro del software.

Blockchain en Votación Electrónica

La tecnología blockchain ofrece un mecanismo distribuido para registrar transacciones de forma segura, transparente e inmutable. Estas características la convierten en una alternativa prometedora para sistemas de votación electrónica, donde resulta fundamental garantizar la integridad de los votos y evitar su manipulación.

Su implementación permite mejorar la trazabilidad y verificabilidad del proceso electoral, incrementando la confianza de los participantes. No obstante, su adopción requiere considerar aspectos relacionados con la privacidad, la escalabilidad y el cumplimiento de requisitos legales y tecnológicos.